Requirements and Acceptance

Secure Inter-Campus Communication Network | Group 03 | M1 design

Scope and authority

This project protects a two-campus university network across an untrusted WAN. M1 fixes requirements, topology, trust, PKI and protocol designs, threats, responsibilities and an observable HTTP baseline. This package prepares M1 only. It does not implement the M2 PKI, crypto tool or TLS portal, or the M3 VPN/KDC/attacks.

Authority: assignment v1.0, pp. 1-11. Section 9 (p. 7) defines M1; sections 7-8 (pp. 5-7) define cumulative FR/SR; section 12 (p. 10) defines the final repository structure. Mandatory requirements below come from that assignment; numerical design choices are identified as proposals, not extra grading rules.

The instructor Starter Kit was not supplied, according to the user. lab/ is an independently authored reconstruction, not instructor material. The specification prohibits lab/ changes without written approval; equivalence/acceptance of this replacement has NOT been approved. This discrepancy must be resolved before submission. Two members are used with instructor approval reported by the user. The original M1 deadline is 06 November 2026; no extension is assumed.

Functional requirements and traceability

Implementation and acceptance evidence in this table are future work unless explicitly marked M1. R=Requirements; T=Topology; P=PKI; D=Protocol; S=STRIDE; W=TeamPlan, all in docs/M1/.

ID	Required behavior and measurable acceptance	Design / planned evidence
FR01	Build the complete two-tier PKI from an empty directory by script. A second clean build follows the same profiles and succeeds; random keys/serials need not be identical.	P; future build transcript and inventory; T1/T13.
FR02	Issue from CSRs using named profiles; every legitimate chain passes openssl verify with intended purpose, SAN and extensions. Rogue chain fails.	P; certificate text, verification outputs; T1.
FR03	Revoke a certificate, publish a fresh CRL; nginx rejects revoked staff and strongSwan rejects revoked gateways.	P/D; dated CRL and refusal logs; T4/T8.
FR04	Final portal HTTPS only; HTTP redirects except documented CRL distribution endpoint; HTTPS supplies HSTS.	D; curl headers, testssl; T6. M1 HTTP is a deliberate baseline exception.
FR05	/staff/ requires valid client certificate, displays/logs its identity; missing or revoked certificate refused generically.	D; valid/absent/revoked results; T3/T4.
FR06	Final lab starts certificate-authenticated IKEv2 tunnel automatically. M1 must NOT start it.	T/D; swanctl --list-sas plus startup log in M3; T7.

ID	Required behavior and measurable acceptance	Design / planned evidence
FR07	Tunnel selectors only 10.3.1.0/24 <-> 10.3.2.0/24. Non-matching traffic is not protected by that child SA.	T/D; installed policies and WAN capture; T7/T10.
FR08	Tool signs/verifies, MACs/verifies, AEAD encrypts/decrypts, agrees keys, rejects tampering.	D (algorithm policy); future known-answer and modified-byte tests; T2.
FR09	KDC authenticates staff and issues TGT then service ticket; wrong credentials refused generically.	D; AS/TGS logs and positive/negative runs; T11.
FR10	Client/service mutually authenticate and confirm fresh session key; duplicate authenticator refused.	D/S; AP transcript and replay refusal; T11/T12b.
FR11	README rebuilds system from clean machine with ordered scripts and real evidence.	R/W; M1 lab recipe, later clean rebuild; T13.
FR12	Weak TLS/PSK/no-freshness variants stay under attacks/, never loaded into final services.	S/W; configuration review and controlled T12a/T12b.

Mandatory security constraints

These are cumulative project constraints relevant to M1 design, not claims of implementation.

SR	Design acceptance and planned verification
SR01	Approved AEAD, SHA-256+, ECDSA/Ed25519, RSA >=3072/PSS for new signatures, ECDH/X25519; library primitives only; CSPRNG and unique per-key nonces. Verify code and tamper tests later.
SR02	Offline encrypted Root; pathlen 1/0; proper KU/EKU and end-entity SAN; random unique serials. Verify profile and certificate inventory.
SR03	Dated CRLs enforced by nginx and strongSwan. Test valid/revoked/missing/expired cases; document CRL vs OCSP and fail policy.
SR04	TLS >=1.2, TLS 1.3 enabled, AEAD/PFS only, leaf+intermediate chain, HSTS, no HIGH/CRITICAL testssl results.
SR05	/staff/ client verification, verify depth, CRL, subject logging and generic rejection. T3/T4.
SR06	Lab DNS-spoof/rogue-CA MITM refused; insecure verification-off comparison confined to attacks/. T5.
SR07	Certificate-only IKEv2, pinned identity, explicit AEAD/ECDH proposals, PFS, rekey and DPD. T7/T8 and weak-proposal refusal.
SR08	Final WAN only UDP 500/4500 and ESP; fail-closed LAN forwarding on tunnel loss. T9/T10. M1 scoped clear HTTP/ICMP is removed in M3.

SR	Design acceptance and planned verification
SR09	AS/TGS/AP with authenticated tickets, AAD, HKDF keys, bounded freshness, replay cache, mutual authentication; no transmitted long-term keys.
SR10	Separate weak protocol replay succeeds, same replay fails after fix. T12a/T12b; not run in M1.
SR11	No secrets/.env/p12/key logs/PSK in Git; mode 600 private keys; full-history scan before tags.
SR12	Real WAN before/after captures with known-string search; later isolated TLS key-log exercise, followed by deleting key log.
SR13	TLS 1.0/1.1, non-AEAD/non-PFS and weak IKE offers rejected. Planned later negative tests.
SR14	Unified results include expected/actual, date, actual tester, commands, evidence and fix notes. No invented PASS or contributor.

Actors and use cases

Actor	Preconditions / action	Success / refusal
Staff Member	Holds own staff key/certificate and group Root trust; connects from client-br to /staff/. Separately uses its own long-term KDC credential for AS/TGS/AP.	Valid unrevoked certificate shows identity; valid tickets confirm session key. Missing/revoked cert, bad credential, stale or duplicate authenticator rejected.
Public Visitor	Trusts group Root and resolves portal name in the lab; opens public /.	HTTPS public content without client certificate. Untrusted server or old TLS fails; /staff/ remains restricted. No real external visitor access is exposed by M1.
Administrator	Authorized local operator; maintains profiles, CRLs, trust stores and gateway policy.	Builds inventory, revokes cert, atomically publishes CRL, checks refusal logs, rebuilds via README. Root signing occurs only offline; secrets excluded.

M1 acceptance gates

Gate	Acceptance / current state
A1	Six required PDFs exist and are visually reviewed; editable sources retained. Status is recorded in evidence/sanitized_logs/M1_static_review.json.
A2	Group 03 names/addresses agree across diagrams, Compose and live node inspection. Runtime route/isolation checks are recorded in evidence/sanitized_logs/M1_runtime_checks.json.
A3	>=8 lab-specific threats with likelihood, impact, controls and planned checks. See S.
A4	PASS: six healthy nodes, client-br HTTP to web-hq and real gw-hq WAN capture. evidence/pcaps/M1_baseline_wan.pcap contains 10 packets, readable GET at frame 4 and HTTP 200/body at frame 6.

Gate	Acceptance / current state
A5	PASS for scripted execution: capture session records UTC, eth1 WAN interface, filter and commands; runtime log records requester and results. Independent member retest/review remains unclaimed.
A6	Assignment requires private GitHub plus final timestamped M1 tag. Team requested Public instead; anonymous reading is verified. Instructor acceptance of this visibility exception and M1 tag remain pending. Secrets are scanned; no tag is created while gates remain unresolved.
A7	Starter Kit replacement discrepancy disclosed and acceptance clarified; member data confirmed. Names/IDs received; kit approval remains unresolved.

Optional choices and exclusions

PDF rather than XLSX for STRIDE is explicitly permitted. Additional threats and machine-readable static validation are optional improvements. Suggested interface names/ports in section 7.1 are not all mandatory; gateway swanctl paths are fixed. Future-stage directories reserve structure only. No future-stage certificates, keys, executable protocol, attack or VPN configuration are delivered as working M1 functionality.

The real baseline uses internal, isolated Docker bridges with masquerading disabled. Docker's internal-subnet filter also blocked legitimate off-subnet packets travelling to a router container. lab/host_l2_transit.py adds only same-project-bridge, lab-address rules in DOCKER-USER. No global firewall policy, bridge sysctl, external interface or NAT rule is changed. Both the rules and live egress restrictions are checked by the M1 runner.